

VISÃO COMERCIAL

VulnScan Toolkit

Avaliações de Vulnerabilidade Web Mais Rápidas, Consistentes e Auditáveis

Proposta de Projeto de Inovação · Julho de 2026 · CIESC

Elaborado por: Higor Silva

1. O Problema

Hoje, as avaliações de segurança de aplicações web dependem de rodar manualmente diversas ferramentas open-source independentes — uma para SQL Injection, outra para Cross-Site Scripting, outra para checagens gerais de misconfiguração. Cada ferramenta tem sua própria sintaxe de comando, formato de saída e escala de severidade. Analistas gastam uma parcela desproporcional do tempo em trabalho manual e repetitivo: disparar ferramentas uma a uma, esperar resultados, traduzir saídas inconsistentes para um vocabulário comum e montar manualmente um relatório antes que qualquer achado chegue a um tomador de decisão.

Isso gera três custos recorrentes para a organização: prazos mais longos nas avaliações de segurança, qualidade de relatório inconsistente dependendo de qual analista executou o scan, e um risco real de scans mal configurados ou não autorizados serem executados contra o alvo errado.

2. A Solução

O VulnScan Toolkit é um único comando containerizado que orquestra múltiplos scanners open-source consagrados no mercado (sqlmap, OWASP ZAP, Nikto, Nuclei) e produz automaticamente um relatório consolidado e profissional — em HTML e PDF — com sumário executivo, pontuação de criticidade alinhada ao framework padrão de mercado CVSS, evidência técnica para cada achado e recomendações concretas de mitigação.

Em vez de um analista rodar quatro ferramentas e escrever um relatório à mão, um único comando produz um entregável padronizado em uma fração do tempo, sempre da mesma forma.

3. Principais Benefícios

Benefício	Impacto
Economia de tempo	Substitui horas de execução manual de ferramentas e montagem de relatório por uma única execução automatizada
Consistência	Todo relatório segue a mesma estrutura e escala de severidade, independentemente de quem executa o scan
Travas de segurança embutidas	Controle de escopo baseado em allowlist bloqueia, por design, scans contra alvos não autorizados
Custo zero de licenciamento	Construído inteiramente sobre ferramentas open-source consolidadas e ativamente mantidas — sem custos por licença ou por scan
Portátil e isolado	Distribuído como container Docker; roda de forma idêntica em qualquer máquina sem conflitar com ferramentas já instaladas (ex: Kali Linux)
Extensível	

Design modular — novas classes de vulnerabilidade/ferramentas podem ser adicionadas sem retrabalhar o núcleo do sistema

4. Quem se Beneficia

- **Equipes de segurança/TI** — ciclos de avaliação mais rápidos, mais tempo para análise manual aprofundada em vez de operar ferramentas manualmente.
- **Gestão** — um formato de relatório padronizado, apresentável à diretoria, com sumário executivo que não exige background técnico para interpretação em alto nível.
- **Equipes de desenvolvimento** — recomendações de mitigação claras e acionáveis, associadas a endpoints e parâmetros específicos, reduzindo idas e vindas sobre achados vagos.

5. Posicionamento vs. Alternativas

Abordagem	Custo	Consistência	Velocidade
Varredura manual com múltiplas ferramentas	Apenas tempo do analista	Baixa — depende do indivíduo	Lenta
Plataformas DAST comerciais	Alto custo de licenciamento	Alta	Rápida
VulnScan Toolkit	Sem custo de licenciamento (stack open-source)	Alta — pipeline padronizado	Rápida

O VulnScan Toolkit mira o meio-termo: os benefícios de consistência e velocidade tipicamente associados a plataformas comerciais, construídos sobre uma base open-source de custo zero de licenciamento, adaptada ao escopo e ao fluxo de trabalho da própria organização.

6. Status Atual e Próximos Passos

O núcleo do sistema (orquestrador, modelo de dados normalizado, motor de relatórios) e quatro módulos de varredura cobrindo reconhecimento, SQL Injection, XSS e XXE já estão implementados como um MVP funcional. O roadmap à frente foca em paralelizar as varreduras para ganho de velocidade, expandir a cobertura de módulos e refinar o relatório para consumo por um público mais amplo de stakeholders (incluindo uma visão de resumo não técnico e gráficos visuais de severidade).

Este projeto é apresentado como uma iniciativa interna de inovação: uma demonstração prática de como ferramentas de segurança open-source já existentes podem ser consolidadas em uma capacidade interna eficiente e reutilizável, sem custo de licenciamento, com controles de segurança e autorização incorporados desde o primeiro dia.